Post-Incident Analysis and Continuous Improvement

Date: 31-03-2026

Prepared by: Yogesh Kumar Agrahari

Table of Contents

1. Post-Incident Analysis and Continuous Improvement
2. Root Cause Analysis (RCA) Methods
3. Fishbone (Ishikawa) Diagram – Theory & Lab
4. Post-Mortem Process
5. SOC Metrics – MTTD, MTTR, Dwell Time
6. Metrics Calculation Lab
7. Continuous Improvement Cycle
8. Lessons Learned Document
9. Documentation & Reporting Templates

1. Introduction – Post-Incident Analysis:

Post-Incident Analysis (PIA) is the structured process of examining a security incident after it has been resolved to understand what happened, why it happened, and how to prevent recurrence. It is one of the most valuable activities a SOC team can perform, yet it is often skipped due to time pressure.

Goals of PIA:

- Identify the root cause of the incident (not just the symptoms).
- Document the full incident timeline for audit and compliance.
- Identify gaps in detection, response, and people/process/technology.
- Create actionable improvement items with owners and deadlines.
- Share lessons with the broader team to prevent knowledge silos.
- Calculate and track performance metrics (MTTD, MTTR, dwell time).

Phase	Activity	Output	Responsible
1.Preparation	Establish playbooks, tools, escalation paths	IR Plan	SOC Manager
2.Detection	Identify incident via SIEM/EDR	Alert + Ticket	L1 Analyst
3.Containment	Isolate affected systems, block IOCs	Containment Report	L2 Analyst
4.Eradication	Remove malware, reset credentials	Eradication Log	L2/L3 Analyst
5.Recovery	Restore services, verify integrity	Recovery Sign-off	SOC Lead
6.Post-Incident	RCA, lessons learned, metric update	PIR Report	All Team

2. Root Cause Analysis (RCA) Methods:

The 5 Whys method iteratively asks 'Why?' to drill down from a symptom to the fundamental root cause. Applied to a phishing incident detected on 30-03-2026:

Method	Best For	Complexity	Output
5 Whys	Single-cause incidents, quick analys	Low	Root cause statement
Fishbone (Ishikawa)	Multi-cause incidents, team analysis	Medium	Cause-effect diagram
Fault Tree Analysis	Complex system failures, safety-criti	aHigh	Boolean logic tree
CATWOE	Process/organisational failures	Medium	System view of problem
Timeline Analysis	Sequence of events reconstruction	Medium	Incident timeline

Five Whys Method — Step by Step:

Step	Question	Answer
Why 1	Why was the phishing email successful?	The user clicked the malicious link in the email.
Why 2	Why did the user click the link?	The email appeared legitimate — no visual warning was shown.
Why 3	Why was no warning shown?	The email filtering rules did not detect the spoofed domain.
Why 4	Why did the filter miss the domain?	The domain was registered 2 days ago — not in blocklists yet.
Why 5	Why was a new domain not blocked?	No rule existed to flag newly registered domains (< 30 days old).
Root Cause	IDENTIFIED	Absence of newly-registered-domain detection rule in email security gateway.

Action Items from 5 Whys:

→ Add email gateway rule: block/quarantine emails from domains < 30 days old

→ Enable DMARC, DKIM, SPF enforcement on all incoming emails

→ Conduct phishing simulation training for all users quarterly

→ Subscribe to threat intel feeds providing newly-registered domain IOCs

Google Sheets – 5 Whys Template Setup:

• Open Google Sheets → New Spreadsheet → Rename to '5Whys_TH2026001'.

• Create columns: Why #, Question, Answer, Owner, Deadline.

• Fill in from the table above.

• Add a 'Root Cause Summary' cell at the bottom with a red background.

• Share with SOC team lead for review.

3. Fishbone (Ishikawa) Diagram – Theory & Lab:

The Fishbone Diagram organises potential causes of an incident into categories, providing a visual map of contributing factors. The 'spine' of the fish points to the problem statement (effect).

Fishbone Categories for Security Incidents:

Category	Security Example	Phishing Incident Cause
People	User behaviour, training gaps	User not trained to identify phishing
Process	Policy gaps, workflow issues	No email security review process
Technology	Tool failures, misconfigs	SPF/DKIM not configured
Environment	Network, physical security	Remote work – personal device used
Management	Oversight, resource allocation	Security budget cut email security
Measurement	Metrics, monitoring gaps	No phishing simulation programme

Creating Fishbone Diagram in Draw.io:

1. Go to https://app.diagrams.net (Draw.io).
2. New Diagram → Select 'Fishbone Diagram' template (or start blank).
3. Set the problem statement (head of fish): 'Phishing Breach – Credential Theft'.
4. Add 6 diagonal 'bones': People, Process, Technology, Environment, Management, Measurement.
5. Add sub-causes to each bone from the table above.
6. Export as PNG/SVG → Add to your GitHub documentation folder.
7. Save as XML file: File → Save As → 'fishbone_phishing_2026-03-30.xml'.

4. Post-Mortem Process:

A post-mortem (or post-incident review) is a formal meeting and document produced after a security incident. It should be blameless — focused on process and system improvement, not individual fault.

Agenda Item	Duration	Owner
Incident Timeline Review	15 min	Incident Lead
Impact Assessment	10 min	SOC Manager
5 Whys / RCA Presentation	20 min	Lead Analyst
Fishbone Diagram Review	10 min	Lead Analyst
Action Items Brainstorm	20 min	All Team
Assign Owners & Deadlines	10 min	SOC Manager
Metrics Review (MTTD/MTTR)	10 min	SOC Analyst
Wrap-up & Documentation	5 min	All Team

Post-Mortem Document Template:

A post-mortem meeting should occur within 5 business days of incident closure. Follow this agenda:

1 Incident Overview (10 min)

Brief summary of what happened, when, and impact scope.

2 Timeline Review (15 min)

Walk through chronological timeline — detection, escalation, containment, resolution.

3 RCA Findings (20 min)

Present 5 Whys results and Fishbone diagram. Discuss root cause consensus.

4 What Went Well (10 min)

Identify and celebrate effective detection/response actions.

5 What Needs Improvement (20 min)

Identify gaps in process, tooling, training, and documentation.

6 Action Items (15 min)

Assign specific, time-bound improvement tasks to responsible owners.

5. SOC Metrics — MTTD, MTTR, Dwell Time:

These three metrics are the foundation of SOC performance measurement:

Metric	Full Name	Definition	Target	Improvement Lever
MTTD	Mean Time to Detect	Time from incident start → SIEM alert fires	< 1 hour (ideal)	Improve detection rules, tuning
MTTR	Mean Time to Respond	Time from alert → incident fully contained	< 4 hours (ideal)	Improve playbooks, automation
Dwell Time	Adversary Dwell Time	Time attacker was in network before detection	< 24 hours	Better threat hunting, EDR
FP Rate	False Positive Rate	% of alerts that are NOT real threats	< 10%	Tune detection rules
Resolution Rate	Incident Resolution Rate	% of cases fully resolved within SLA	> 95%	Improve staffing, runbooks

5.1 Mean Time to Detect (MTTD)

```
# MTTD Calculation — 30-03-2026 Phishing Incident
# Formula: MTTD = Detection Time - Compromise Time
# Timeline:
# 09:00 AM — Phishing email delivered (Compromise Begins)
# 11:00 AM — Wazuh alert fired (Detection Event)
compromise_time  = "09:00"   # 9:00 AM
detection_time   = "11:00"   # 11:00 AM
MTTD_minutes     = 120       # 2 hours
print(f"MTTD = {MTTD_minutes} minutes ({MTTD_minutes/60:.1f} hours)")
# Output: MTTD = 120 minutes (2.0 hours)
# Target MTTD: < 60 minutes
# Status: NEEDS IMPROVEMENT (2x above target)
```

5.2 Mean Time to Respond (MTTR)

```
# MTTR Calculation — 30-03-2026 Phishing Incident
# Formula: MTTR = Resolution Time - Detection Time
# Timeline:
# 11:00 AM — Detection (Wazuh alert)
# 03:00 PM — Full containment (IP blocked, email quarantined, user notified)
```

```
detection_time   = "11:00"   # 11:00 AM
resolution_time  = "15:00"   # 3:00 PM
MTTR_minutes     = 240       # 4 hours
print(f"MTTR = {MTTR_minutes} minutes ({MTTR_minutes/60:.1f} hours)")
# Output: MTTR = 240 minutes (4.0 hours)
# Target MTTR: < 60 minutes with full SOAR automation
# Status: HIGH — manual steps caused delay; automate with playbook.
```

5.3 Additional SOC KPIs

Metric	Formula	30-03-2026 Value	Target	Status
MTTD	(Detection Time - Compromise Time)	2 hours	< 1 hour	NEEDS IMPROVEMENT
MTTR	(Resolution - Detection Time)	4 hours	< 1 hour	NEEDS IMPROVEMENT
Dwell Time	(MTTD + MTTR)	6 hours	< 2 hours	CRITICAL
False Positive Rate	(FP Alerts / Total Alerts) x 100	18%	< 10%	NEEDS TUNING
Alert Volume	Total alerts per shift	47 alerts	< 30/shift	HIGH
Escalation Rate	(Escalated / Total) x 100	8.5%	5-15%	NORMAL

6. Metrics Calculation Lab:

Perform this lab using Google Sheets with the mock incident data provided.

Mock Incident Data (30 March 2026):

Incident ID	Start Time	Detection Time	Containment Time	Resolution Time
INC-001	2026-03-30 09:15	2026-03-30 10:05	2026-03-30 11:00	2026-03-30 11:45
INC-002	2026-03-30 12:30	2026-03-30 12:52	2026-03-30 13:15	2026-03-30 14:00
INC-003	2026-03-30 15:00	2026-03-30 16:30	2026-03-30 16:45	2026-03-30 17:30
INC-004	2026-03-30 20:00	2026-03-31 00:30	2026-03-31 01:00	2026-03-31 02:15

Calculated Metrics:

Metric	INC-001	INC-002	INC-003	INC-004	AVERAGE
MTTD (minutes)	50 min	22 min	90 min	270 min	108 min
MTTR (minutes)	150 min	90 min	150 min	255 min	161 min
Dwell Time (minutes)	50 min	22 min	90 min	270 min	108 min
Resolution Time (min)	150 min	90 min	150 min	255 min	161 min

7. Continuous Improvement Cycle:

Phase	Activities	Output
PLAN	Identify gap from post-mortem → Define improvement initiative	Improvement plan with owner + deadline
DO	Implement change (new rule, playbook, training, tool)	Updated detection rule / playbook / policy
CHECK	Measure impact using SOC metrics (MTTD/MTTR before/after)	Metrics comparison report
ACT	Standardise if effective, adjust if not, share with team	Updated SOC runbook / SOP

8. Lessons Learned Document:

Category	Finding	Recommendation	Owner	Due Date
Detection	MTTD was 2h — above 1h target	Tune Wazuh rule sensitivity; add email header analysis	L2 Analyst	07-04-2026
Process	**No email gateway review process**	Create quarterly email security review SLA	**SOC Manager**	**14-04-2026**
Technology	**MFA not on email accounts**	Enforce MFA via Azure AD Conditional Access	**IT Admin**	**10-04-2026**
Training	**User opened phishing email**	Monthly phishing simulation via KnowBe4/GoPhish	**Security Awareness**	**30-04-2026**
Automation	**SOAR playbook not triggered**	Integrate Wazuh rule 100002 with Phantom	**L3 Analyst**	**05-04-2026**

9. Documentation & Reporting Templates:

Incident Summary – 30 March 2026

Field	Value
Incident ID	INC-2026-001
Type	Phishing → Credential Theft
Date/Time	30 March 2026, 09:15
Source IP	10.0.2.20
Affected Asset	WORKSTATION-01, HR Portal
Severity	High
MTTD	50 minutes
MTTR	150 minutes (2h 30m)
Dwell Time	50 minutes
Root Cause	Missing SPF/DKIM + No phishing training
Status	Resolved – 30 March 2026, 11:45